Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 El costo real de la inseguridad

1.4 El SDLC tradicional y la seguridad tardía

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 CAMS: Culture y Automation

1.8 CAMS: Mesurement y Sharing

1.9 La seguridad como proceso continuo



1.6 DevSecOps: integrar seguridad

FADENA

- DevSecOps Manifesto
- DevSecOps
- Security Development Lifecycle (SDL)
- Arquitectura y diseño seguro del software
- ¿Cómo se aplica la seguridad en DevSecOps?



1.6 DevSecOps: integrar seguridad

DevSecOps Manifesto

Ser proactivo en lugar de decir siempre "No"
Ciencia de datos y seguridad en lugar de miedo, incertidumbre y duda
Contribución abierta y colaboración en lugar de requisitos exclusivamente de seguridad
Servicios de seguridad accesibles con API en lugar de controles de seguridad obligatorios y papeleo
Puntuaciones de seguridad orientadas al negocio en lugar de seguridad meramente formal
Pruebas de exploits de equipos rojos y azules en lugar de depender de escaneos y vulnerabilidades teóricas
Monitoreo de seguridad proactivo 24/7 en lugar de reaccionar tras ser informado de un incidente
Inteligencia de amenazas compartida en lugar de información confidencial
Operaciones de cumplimiento en lugar de listas de verificación

1.6 DevSecOps: integrar seguridad

DevSecOps



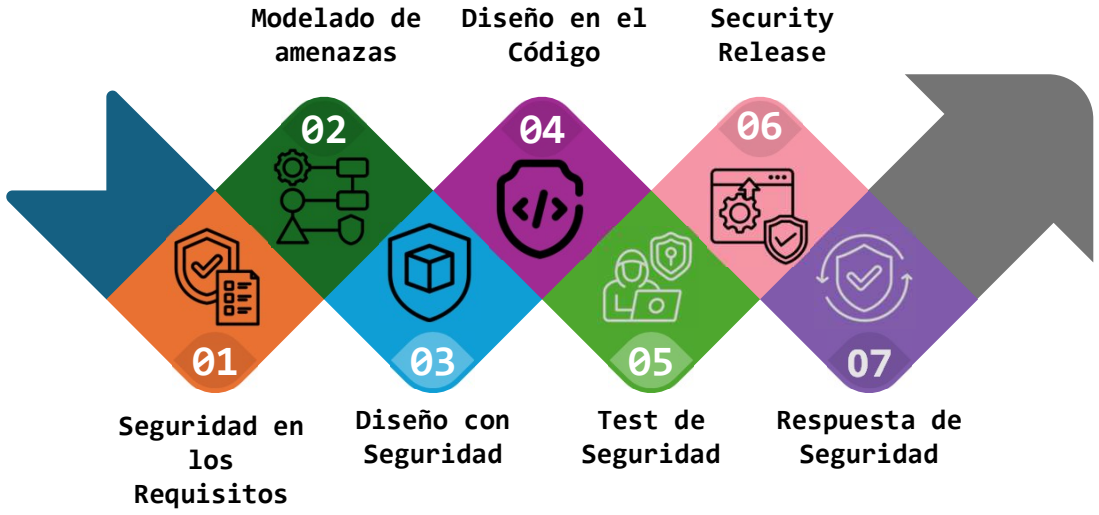
DevSecOps es el subconjunto de DevOps enfocado en la ciberseguridad. DevSecOps se puede interpretar como la intersección del desarrollo, el control de calidad, las operaciones y la ciberseguridad.

1.6 DevSecOps: integrar seguridad

Security Development Lifecycle (SDL)

¿Qué es el SDL?

El ciclo de vida de desarrollo seguro (SDL) es un ciclo en el que las actividades de seguridad se integran en el proceso normal de desarrollo de software, en lugar de añadirse solo al final.



$$M_b + P_b > O_{cp} + O_{cm}P_aP_c$$

M_b es el beneficio monetario para el atacante.
P_b es el beneficio psicológico para el atacante.
O_{CP} es el coste de cometer el delito.
O_{cm} representa el costo monetario de la condena para el agresor (oportunidades futuras perdidas y costos legales).
P_a representa la probabilidad de ser detenido y arrestado.
P_c representa la probabilidad de condena para el agresor.

1.6 DevSecOps: integrar seguridad

Security Development Lifecycle (SDL)

Recomendaciones SDL



Compromiso

Fomentar el compromiso del management y stakeholders respect de incorporar la seguridad en todo el ciclo del Desarrollo.

Conocimiento

Entrenar y compartir conocimiento entre los ingenieros de sistemas.

Modelado de amenazas

Utilizar procesos para el modelado de amenazas.

Revisión de código

Aplicar herramientas y revisión de código para detectar y eliminar errores de codificación comunes que provocan vulnerabilidades de seguridad.

Test de Seguridad

Aprender a pensar como un hacker.

Respuesta de Seguridad

Céntrese en la necesidad de un proceso de respuesta de seguridad posterior al lanzamiento.

Grupo de Productos

Organizar grupos de productos para mejorar la seguridad

- Establecer un equipo de seguridad dedicado dentro del grupo de producto.
- Definir un criterio consistente para evaluar la criticidad de las posibles vulnerabilidades de seguridad.
- Registrar los errores de seguridad encontrados y corregidos, e interiorizar las lecciones aprendidas de los nuevos tipos de errores de seguridad.

FADENA

1.6 DevSecOps: integrar seguridad

Arquitectura y diseño seguro del software



Ideas a Realidad

La arquitectura convierte los requisitos ("qué" y "por qué") en decisiones concretas ("quién, cuándo, dónde y cómo").

SDLC

Es la fase más crítica para la seguridad. Las decisiones erróneas en el diseño provocan fallas que no se pueden solucionar en fases de codificación o pruebas

Seguridad vs. Software

Software de seguridad: Componentes específicos (WAF, cifrado).
Arquitectura segura: Un diseño global resiliente y resistente a ataques.

Comportamiento esperado

La seguridad no es solo funcional; asegura que el software haga lo que debe hacer y NADA más.

Análisis de Riesgos de Arquitectura

Incluye el modelado de amenazas, análisis de riesgo y planificación de mitigación.

Gestión continua

Ningún sistema es 100% seguro; el objetivo real es mantener un perfil de riesgo minimizado de forma continua.

FADENA

1.6 DevSecOps: integrar seguridad

Arquitectura y diseño seguro del software

Arquitectura versus seguridad

Software de Seguridad

Herramientas específicas como WAFs o paquetes de cifrado.

Seguridad del Software

La práctica integral de construir un sistema inherentemente seguro.

Arquitectura de Seguridad

Estructura y disposición de los componentes de seguridad.

Arquitectura Segura

Un diseño global resiliente y verdaderamente resistente a ataques.

1.6 DevSecOps: integrar seguridad

Arquitectura y diseño seguro del software

Estrategia

Identifica y resuelve fallas de diseño desde el inicio, evitando que se conviertan en vulnerabilidades graves en producción y mejorando la resiliencia de la aplicación.

Clave

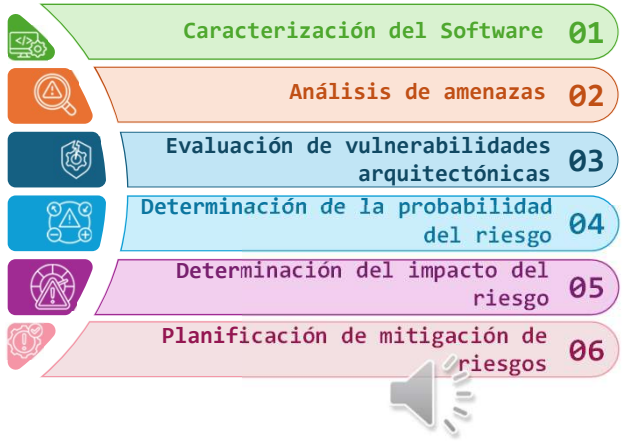
Requiere entender el propósito de negocio del sistema y tener una identificación clara de los activos que el software utiliza o protege.

Cuantificación del Riesgo

Evalúa la probabilidad de un ataque (analizando amenazas, vulnerabilidades potenciales y controles existentes).

Mitigación del Riesgo

Permite seleccionar e implementar los controles y acciones de mitigación precisos para reducir o eliminar los riesgos identificados.



FADENA

1.6 DevSecOps: integrar seguridad

Cómo se aplica la seguridad en DevSecOps?

